

ABC of CYBER

Security Policy Template

Company-wide information security policy framework

Document Ref:	IS-POL-001
Version:	1.0
Effective Date:	25 July 2026
Approved By:	[Chief Information Security Officer]
Review Date:	25 July 2027

[TEMPLATE -- Replace bracketed text with your organisation's details]

1. PURPOSE

This policy establishes the information security framework for [Organisation Name]. It defines the principles, responsibilities, and minimum requirements for protecting the confidentiality, integrity, and availability of information assets.

2. SCOPE

This policy applies to all employees, contractors, consultants, and third-party personnel who access, process, or manage information assets belonging to [Organisation Name]. It covers all information systems, networks, applications, physical locations, and data processing activities, regardless of location or ownership.

3. POLICY STATEMENTS

3.1 Access Control

Access to information systems and data shall be granted on a least-privilege basis. User access requests must be authorised by the data owner. Privileged access requires separate approval and quarterly recertification. Multi-factor authentication is mandatory for remote access, administrative accounts, and any system containing sensitive data.

3.2 Data Handling & Classification

All data shall be classified as Public, Internal, Confidential, or Restricted. Handling requirements -- including encryption at rest and in transit, data loss prevention, retention schedules, and secure disposal -- correspond to classification level. Confidential and Restricted data must not be stored on personal devices without authorised encryption software.

3.3 Incident Reporting

All security incidents, suspected breaches, and anomalous events must be reported to the Security Operations team within [1 hour / 4 hours] of discovery. Reports must include: date/time of discovery, description of the event, systems affected, and immediate actions taken. Retaliation against good-faith reporters is strictly prohibited.

3.4 Password Policy

Passwords must be a minimum of 12 characters and should not be reused across organisational accounts. Passphrases are encouraged. Accounts are locked after 5 failed attempts. Password managers are mandatory for all personnel. Shared credentials are prohibited; service accounts must use certificate or token-based authentication where possible.

3.5 Remote Work & Mobile Security

Remote access must be established via VPN with multi-factor authentication. Personal devices used for work must have disk encryption, screen lock, and approved endpoint protection installed. Company data may not be stored on unmanaged devices. Public Wi-Fi must only be used with VPN active and HTTPS enforced.

4. ENFORCEMENT & COMPLIANCE

Compliance with this policy is mandatory. Violations may result in disciplinary action, up to and including termination of employment or legal action.

The Security Team conducts periodic audits, automated scans, and random inspections to verify compliance. Non-compliant systems may be disconnected from the network until remediated.

5. POLICY REVIEW

This policy shall be reviewed annually, or when significant changes occur in the regulatory environment, technology stack, or business operations. Suggestions for improvement should be directed to the Information Security team at security@[organisation].com.

AUTHORISATION

[Name], Chief Information Security Officer

Date

[Name], Chief Executive Officer

Date